

GSG-02

Security Review Checklist

52 Questions Across 8 Areas of Your Business

A structured review tool for business owners who want a clear picture of where their security stands. Work through each section, mark your answers, and use the results to prioritize what to improve.

HOW TO USE THIS CHECKLIST

For each question, mark **Yes** (fully in place), **Partly** (partially done or inconsistent), or **Not Yet** (not in place). Add notes where helpful. Use your results to identify gaps and decide what to prioritize.

Answer	Points	What it means
Yes	2	This protection is fully in place
Partly	1	This is partially done or not done consistently
Not Yet	0	This protection is not yet in place

YOUR SCORE SUMMARY

Area	Score	/ Max	Rating
01 Protecting Your Physical Space	_____	/ 12	_____
02 Controlling Who Can Access What	_____	/ 14	_____
03 Securing Your Network and Devices	_____	/ 14	_____
04 Protecting Your Business Information	_____	/ 14	_____
05 Being Ready When Something Goes Wrong	_____	/ 12	_____
06 Managing Your Outside Vendors and Software	_____	/ 12	_____
07 Building a Security-Aware Team	_____	/ 14	_____
08 Staying Safe in the Cloud and Working Remotely	_____	/ 12	_____
TOTAL SCORE	_____	/ 104	_____

75-100% Well Protected 50-74% Some Gaps 25-49% Action Needed 0-24% Immediate Attention Required

01 Protecting Your Physical Space

Max 12 points

#	Question	Yes	Partly	Not Yet	Notes
1	Is the room or closet where your computer servers or main network equipment is kept locked and only accessible to people who need to be there?	☐	☐	☐	
2	Do you keep a record of who enters your server room or equipment area, and when?	☐	☐	☐	
3	When employees step away from their computers, do the screens lock automatically or do staff lock them manually?	☐	☐	☐	
4	Do you have security cameras covering the entrances to your office or building?	☐	☐	☐	
5	Are backup hard drives, USB drives, and sensitive printed documents stored in a locked cabinet or safe when not in use?	☐	☐	☐	
6	When an employee leaves your business, is there a process to collect their keys, access cards, and update any door codes they knew?	☐	☐	☐	

Area 01 Score _____ / 12 Rating: _____

02 Controlling Who Can Access What

Max 14 points

#	Question	Yes	Partly	Not Yet	Notes
1	Does every person who uses your systems have their own individual login? Or do people share usernames and passwords?	☐	☐	☐	
2	When staff log into email or business software, is there a second verification step — like a code sent to their phone — beyond just a password?	☐	☐	☐	
3	Do your employees only have access to the systems and files they need for their specific job — nothing more?	☐	☐	☐	
4	Do the people who manage your IT systems use a separate, special account for those tasks — different from their everyday work account?	☐	☐	☐	
5	When a new employee joins, is there a clear process for setting up their accounts? When someone leaves, are their accounts disabled right away?	☐	☐	☐	
6	Do you review who has access to what at least once a year to make sure it still makes sense?	☐	☐	☐	
7	Does your business have a clear rule about how passwords should be created — including how long they should be and that they should not be reused?	☐	☐	☐	

Area 02 Score _____ / 14 Rating: _____

03 Securing Your Network and Devices

Max 14 points

#	Question	Yes	Partly	Not Yet	Notes
1	Does your business use a professional-grade firewall — not just the basic router that came from your internet provider?	☐	☐	☐	
2	Is the Wi-Fi network your customers or visitors use completely separate from the one your staff and business systems use?	☐	☐	☐	
3	Are the routers, switches, and Wi-Fi access points in your office set up with custom passwords — not the factory defaults they came with?	☐	☐	☐	
4	Do you have any way of knowing if something unusual is happening on your network — like a large amount of data being sent out overnight?	☐	☐	☐	
5	If employees work remotely, do they connect to your business systems through a secure, approved method — rather than just logging in directly from home?	☐	☐	☐	
6	Do all of your business computers and laptops have up-to-date security software installed — beyond just the basic protection that came with the device?	☐	☐	☐	
7	Is there a process to make sure your computers, software, and network equipment get security updates applied in a timely way?	☐	☐	☐	

Area 03 Score _____ / 14 Rating: _____

04 Protecting Your Business Information

Max 14 points

#	Question	Yes	Partly	Not Yet	Notes
1	Do you have a clear understanding of what sensitive information your business holds — such as client personal details, payment information, or health records?	☐	☐	☐	
2	If a laptop or hard drive was stolen from your office, would the information on it be unreadable to the thief?	☐	☐	☐	
3	When your business sends sensitive information by email or through your website, is it sent in a way that cannot be intercepted?	☐	☐	☐	
4	Does your business back up its important data regularly — and do you actually test that you can restore from those backups?	☐	☐	☐	
5	Does your business have a clear policy about how long you keep different types of records, and how you safely dispose of them when no longer needed?	☐	☐	☐	
6	Do you know which outside companies or software tools have access to your business data, and have you checked that they handle it responsibly?	☐	☐	☐	
7	Is there a way to know if someone is accessing sensitive files or records they should not be looking at?	☐	☐	☐	

Area 04 Score _____ / 14 Rating: _____

05 Being Ready When Something Goes Wrong

Max 12 points

#	Question	Yes	Partly	Not Yet	Notes
1	Does your business have a written plan for what to do if you experience a cyberattack, data breach, or other security emergency?	☐	☐	☐	
2	Has your team actually walked through that plan in the last 12 months — even as a practice exercise — to make sure everyone knows their role?	☐	☐	☐	
3	Does every member of your team know exactly who to call first if they think something has gone wrong?	☐	☐	☐	
4	Does your business have insurance that covers the costs of responding to a data breach or cyberattack?	☐	☐	☐	
5	If a cyberattack happened today, do you know how to preserve evidence without accidentally making things worse?	☐	☐	☐	
6	Do you know whether your business is legally required to notify clients or regulators if their information is ever exposed in a breach?	☐	☐	☐	

Area 05 Score _____ / 12 Rating: _____

06 Managing Your Outside Vendors and Software

Max 12 points

#	Question	Yes	Partly	Not Yet	Notes
1	Do you have a current list of every outside company, contractor, or software tool that can access your business systems or client information?	☐	☐	☐	
2	Before you give a new vendor or software tool access to your business, do you check their security practices?	☐	☐	☐	
3	Do your contracts with vendors include clear expectations about how they protect your data and what happens if there is a breach?	☐	☐	☐	
4	When a vendor needs to access your systems, do they only get access to what they specifically need — and only for as long as they need it?	☐	☐	☐	
5	When you stop working with a vendor, is there a process to make sure they no longer have access to your systems or data?	☐	☐	☐	
6	If your most critical software or service provider suddenly became unavailable, do you have a backup plan to keep your business running?	☐	☐	☐	

Area 06 Score _____ / 12 Rating: _____

07 Building a Security-Aware Team

Max 14 points

#	Question	Yes	Partly	Not Yet	Notes
1	Does every member of your team receive some form of security training at least once a year?	☐	☐	☐	
2	Do your staff know how to spot a suspicious email — including ones that look like they come from a trusted source?	☐	☐	☐	
3	Is there an easy, blame-free way for employees to report something that looks suspicious — without worrying they will get in trouble?	☐	☐	☐	
4	Does your business periodically send practice phishing emails to staff to see how they respond — and use the results to improve training?	☐	☐	☐	
5	When new employees join your team, do they receive security guidance as part of their onboarding?	☐	☐	☐	
6	Has every employee read and acknowledged your key security policies — such as your rules around passwords and acceptable computer use?	☐	☐	☐	
7	Do employees in high-risk roles — such as those who handle payments or have access to sensitive records — receive additional targeted training?	☐	☐	☐	

Area 07 Score _____ / 14 Rating: _____

08 Staying Safe in the Cloud and Working Remotely

Max 12 points

#	Question	Yes	Partly	Not Yet	Notes
1	Do you have a complete list of every cloud application and online service your business uses — including ones staff may have signed up for on their own?	☐	☐	☐	
2	For your cloud platforms like email and file storage, is multi-factor authentication turned on for every account — especially administrator accounts?	☐	☐	☐	
3	When employees work from home or another location, do they use a secure, business-approved connection to access your systems?	☐	☐	☐	
4	If employees use their personal phones or computers for work, are there rules about what they can access and how those devices must be secured?	☐	☐	☐	
5	Are your cloud file storage settings configured so that sensitive documents cannot accidentally be shared with people outside your business?	☐	☐	☐	
6	When an employee who works remotely leaves your business, is there a process to revoke all their cloud access and ensure business data is removed from their personal devices?	☐	☐	☐	

Area 08 Score / 12 Rating:

ABOUT THIS DOCUMENT *Developed with assistance from Claude (Anthropic) and reviewed by Paul Green, CISSP.*